Example Electrical Ltd

DRAFT · missing: postal address of the business, recipient, name of the signatory. Add the answers before sending.

[postal address of the business]

[name and address of the customer or insurer]

[place], 23 October 2026

Subject: Security evidence of Example Electrical Ltd

Dear Sir or Madam,

Thank you for your security questionnaire. Attached you find our security self-declaration as of 23 October 2026. It answers the questions on the state of our information security; where your questionnaire asks something the self-declaration does not cover, the mapping table on the following page shows where the answer is, or we answer in writing on request.

Example Electrical Ltd is a business with 10 to 49 staff and no IT department of its own. We provide services on site or in our workshop and handle some customer data (contacts, plans, orders). The measures described are those of a business of our size; Article 21(1) of the NIS 2 Directive (EU) 2022/2555 names the size of the entity among the criteria of proportionality.

Of the 24 points of the self-declaration, 7 are in place today, 10 partly, 6 not yet, 1 not applicable to us. For every point that is partly or not yet in place, the attached action plan names the measure, the responsible person and the date: the first wave by 22 November 2026, the rest by 21 April 2027. We prefer to name a gap with a date rather than answer yes where it is not true.

We report incidents that may affect you within 24 hours of becoming aware, by phone, through the management or the deputy; the report comes from the owner or managing director, +43 660 000 00 01 (example), office@example.at.

If one of the open points is a condition for the contract or the policy, please tell us; we will move it into the first wave.

Attachments: Security self-declaration; Action plan; Evidence list with the documents numbered Att. 1 to 3.

Kind regards

[name]

Owner or managing director, Example Electrical Ltd

Questionnaire mapping

Questionnaires of different customers ask largely the same things in different words and orders. This table maps the typical questions to the sections of the self-declaration and to the areas of Article 21(2) of the NIS 2 Directive, with our answer in short form.

Typical question	Self-declaration	Art. 21(2)	Our answer
Who is responsible for information security, and how do we reach them?	A	(a), (i)	Owner or managing director, +43 660 000 00 01 (example), office@example.at; deputy: office management
Do you have written security rules or a policy?	B	(a)	Partly, by 21 January 2027
Do you hold a certificate (ISO 27001, label) or audit reports?	B	(f)	None
Do you have cyber insurance?	B	not in Art. 21(2)	No
Is multi-factor authentication enforced for email, remote access and administration?	C	(j)	MFA for email: in place (authenticator app); MFA for remote access and administration: partly (VPN yes, the admin console of the cloud not yet), by 22 November 2026
How are access rights removed when staff leave?	C	(i)	Partly, by 21 January 2027
What is your password policy, and are administrator rights restricted?	C	(i)	Password rule: partly, by 21 January 2027; admin rights: not yet, by 21 January 2027
How often do you back up, is a copy offline, and when was a restore tested?	D	(c)	Backup: partly (daily to the NAS in the office, no offline copy), by 22 November 2026; restore test: not yet, by 22 November 2026
How long can you bridge an IT outage, have you tested a restore, and is there an emergency plan?	D	(c)	Tolerable downtime: about a day; restore test: not yet, by 22 November 2026; emergency plan: not yet, by 22 November 2026
Within what time are updates installed, and are all systems supported?	E	(e)	Updates: in place; device list: partly (no written list; the workshop computer still runs an old system), by 21 January 2027
Are devices protected and encrypted, and is the network segmented?	E	(e), (h)	Protection and encryption: in place; router and guest network: partly (guest network yes, firmware and password unknown), by 21 January 2027
How do you handle vulnerabilities in your products?	E	(e)	Not applicable: we supply no software or devices
Within what time do you notify us of incidents?	F	(b)	Within 24 hours of becoming aware, by phone, through the management or the deputy
Have you had incidents in the last 24 months, and do you log them?	F	(b)	Incidents: none known; incident log: not yet, by 21 January 2027
Do you train staff, and are they bound to confidentiality?	G	(g), (i)	Briefing: not yet, by 21 January 2027; confidentiality: in place

Typical question	Self-declaration	Art. 21(2)	Our answer
Which subcontractors process our data, where, and under which contracts?	H	(d)	Provider list: partly, by 21 January 2027; processing agreements and console settings: partly, by 21 January 2027; notice before a provider change: not yet, by 21 April 2027
How are our data returned or deleted at the end of the contract?	I	not in Art. 21(2)	In place
May we audit you, or receive evidence?	B, I	(f)	Evidence list (D4): we provide it and the documents behind it on request and renew the self-declaration once a year; on-site audits by arrangement, with notice and at the auditing party's cost.

Generated with the Scutoria Security Evidence Toolkit from the answers of the business. Gaps are named with dates, never hidden; nothing here promises that the business meets a rule. Sources read at the original on 23 October 2026: Directive (EU) 2022/2555, Art. 21(1) and (2); Regulation (EU) 2022/2554 (DORA), Art. 30. Source-based. No legal advice.